

Scenario 1 output 2 chatgpt

Threat 1 — Credential Spoofing Through Malicious Login Requests

- **Threat ID:** T1
- **Threat Name:** Credential Spoofing / Authentication Request Manipulation
- **STRIDE Category:** Spoofing
- **Affected Component/Data Flow:** EE1 → P1 → P2 → DS1
- **Attack Scenario:** An attacker submits crafted registration or login requests through P1 using another user's username and guessed, stolen, or manipulated credentials. Since P1 does not authenticate users itself, the request is forwarded to P2 for credential verification. The attacker attempts to cause P2 to incorrectly associate the request with another account.
- **Security Impact:** Unauthorized authentication and account compromise.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation Strategy:** P2 must perform credential verification exclusively against the corresponding salted password hash stored in DS1. P1 must not make authentication decisions or alter authentication results. Authentication requests should be validated for expected structure before reaching P2, and authentication failures should not reveal whether a username exists.
- **OWASP LLM Top 10 Mapping:** Not directly applicable.

Threat 2 — Registration Account Spoofing

- **Threat ID:** T2
- **Threat Name:** Malicious Account Registration
- **STRIDE Category:** Spoofing
- **Affected Component/Data Flow:** EE1 → P1 → P2 → DS1
- **Attack Scenario:** An attacker registers accounts using usernames or account information intended to impersonate legitimate users. Because account creation is performed by P2, malicious registration data can enter DS1 if P2 does not enforce appropriate registration constraints.
- **Security Impact:** Account impersonation, identity confusion, abuse of account functionality, and possible unauthorized access to resources associated with the impersonated identity.
- **Severity:** Medium
- **Likelihood:** Medium
- **Mitigation Strategy:** P2 should enforce username uniqueness, validate registration data, and ensure account creation is performed only according to the defined registration rules. P1 should treat all registration input as untrusted and must not directly write to DS1.
- **OWASP LLM Top 10 Mapping:** Not directly applicable.

Threat 3 — Tampering With Authentication Requests

- **Threat ID:** T3
- **Threat Name:** Authentication Request Tampering
- **STRIDE Category:** Tampering
- **Affected Component/Data Flow:** EE1 → P1 → P2
- **Attack Scenario:** A malicious user manipulates parameters in a login request, such as username, authentication state, or other request fields, attempting to cause P2 to process a request differently from what the user submitted.
- **Security Impact:** Unauthorized authentication, incorrect authentication decisions, or authentication workflow manipulation.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation Strategy:** P2 must independently validate all security-sensitive authentication parameters rather than trusting P1. Authentication state must be derived by P2 rather than supplied by the user. P1 should only transport and display authentication requests and responses.
- **OWASP LLM Top 10 Mapping:** Not directly applicable.

Threat 4 — Password Hash Disclosure

- **Threat ID:** T4
- **Threat Name:** Unauthorized Access to Password Hashes
- **STRIDE Category:** Information Disclosure
- **Affected Component/Data Flow:** P2 ↔ DS1; P4/P5 must not access password hashes
- **Attack Scenario:** A vulnerability in the application or an unintended data flow causes password hash values from DS1 to become accessible to P4 or P5, or potentially included in context sent to EE2.
- **Security Impact:** Offline password cracking, credential compromise, and potential compromise of other accounts where passwords are reused.
- **Severity:** Critical
- **Likelihood:** Low
- **Mitigation Strategy:** Enforce architectural isolation so only P2 accesses credential information in DS1. Password hashes must never be included in chatbot context, prompts, responses, or LLM requests. P4 and P5 must have no mechanism for requesting or retrieving credential data.
- **OWASP LLM Top 10 Mapping:** LLM06 — Sensitive Information Disclosure.

Threat 5 — Session Token Disclosure to the AI Layer

- **Threat ID:** T5
- **Threat Name:** Session Token Exposure
- **STRIDE Category:** Information Disclosure
- **Affected Component/Data Flow:** P3 ↔ DS2; P3/P1/P4/P5 boundaries
- **Attack Scenario:** A session identifier or token is accidentally included in chatbot context, prompt construction, application-level response handling, or data passed from the authentication/session workflow into P4 or P5.
- **Security Impact:** An attacker controlling or obtaining the token could potentially impersonate the authenticated user and access the user's session.
- **Severity:** Critical
- **Likelihood:** Medium

- **Mitigation Strategy:** P3 must keep session tokens isolated from P4 and P5. P5 must explicitly exclude session identifiers and token-related information from prompts and context. P4 must never receive session tokens, even when answering authentication-related questions.
- **OWASP LLM Top 10 Mapping:** LLM06 — Sensitive Information Disclosure.

Threat 6 — Prompt Injection Through Chatbot Input

- **Threat ID:** T6
- **Threat Name:** Direct Prompt Injection
- **STRIDE Category:** Tampering
- **Affected Component/Data Flow:** EE1 → P1 → P4 → P5 → EE2
- **Attack Scenario:** A user submits a chatbot prompt such as instructions pretending to be a system administrator and attempts to override the chatbot's restrictions. The attacker may instruct the LLM to reveal protected information, ignore application rules, or generate content that should not be returned.
- **Security Impact:** Unauthorized information disclosure, unsafe output, policy bypass, and manipulation of the AI assistance layer.
- **Severity:** High
- **Likelihood:** High
- **Mitigation Strategy:** Treat every chatbot prompt as untrusted data. P5 should clearly separate user input from trusted instructions and approved context. Security restrictions must be enforced by application logic rather than relying solely on the LLM to obey instructions. Sensitive data must be excluded before prompt construction.
- **OWASP LLM Top 10 Mapping:** LLM01 — Prompt Injection.

Threat 7 — Indirect Prompt Injection Through Approved Context

- **Threat ID:** T7
- **Threat Name:** Malicious Instruction Injection Through Context
- **STRIDE Category:** Tampering
- **Affected Component/Data Flow:** DS3 → P4/P5 → EE2
- **Attack Scenario:** Content retrieved from DS3 contains text that appears to be an instruction to the LLM rather than authentication documentation. When P5 incorporates the content into the prompt, the LLM interprets the embedded instructions as authoritative.
- **Security Impact:** Manipulated chatbot responses, disclosure of information available to the model, or bypass of intended chatbot behavior.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation Strategy:** P5 should treat DS3 content as untrusted contextual data even though DS3 is an approved repository. Retrieved context should be constrained to approved documentation and clearly separated from system-level instructions. Context should be validated before inclusion in prompts.
- **OWASP LLM Top 10 Mapping:** LLM01 — Prompt Injection.

Threat 8 — Sensitive Information Disclosure Through LLM Responses

- **Threat ID:** T8
- **Threat Name:** LLM-Assisted Sensitive Information Disclosure
- **STRIDE Category:** Information Disclosure
- **Affected Component/Data Flow:** P5 → EE2 → P5 → P4 → P1 → EE1
- **Attack Scenario:** A malicious prompt attempts to cause the LLM to disclose information that should not be revealed. Even though passwords, hashes, session tokens, and secrets are prohibited from crossing into EE2, sensitive application information could still accidentally be included in the prompt or generated response.
- **Security Impact:** Disclosure of authentication-related information, internal application information, or other sensitive data.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation Strategy:** P5 must sanitize prompts and context before transmission to EE2 and enforce an explicit allow-list of information that may cross the external LLM boundary. Responses returned from EE2 must also be treated as untrusted and filtered before reaching P1.
- **OWASP LLM Top 10 Mapping:** LLM06 — Sensitive Information Disclosure.

Threat 9 — Data Leakage Through Prompt Construction

- **Threat ID:** T9
- **Threat Name:** Unauthorized Data Inclusion in LLM Prompts
- **STRIDE Category:** Information Disclosure
- **Affected Component/Data Flow:** P5 → EE2
- **Attack Scenario:** P5 constructs a prompt using application data that was not intended for the external LLM. A developer or application logic error could cause authentication records, account information, session-related data, or other internal information to be incorporated into the prompt.
- **Security Impact:** Sensitive application data leaves the trusted application environment and becomes exposed to a third-party service.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation Strategy:** P5 must construct prompts using an explicit allow-list of approved context from DS3. Authentication credentials, password hashes, session tokens, and secrets must be technically excluded rather than merely relying on instructions to the LLM. Prompt construction should occur independently of P2 and P3 security-sensitive data.
- **OWASP LLM Top 10 Mapping:** LLM06 — Sensitive Information Disclosure.

Threat 10 — Insecure Handling of LLM Output

- **Threat ID:** T10
- **Threat Name:** Malicious LLM Output Injection
- **STRIDE Category:** Tampering
- **Affected Component/Data Flow:** EE2 → P5 → P4 → P1 → EE1
- **Attack Scenario:** The external LLM returns manipulated or malicious content. P5 forwards the response to P4 or P1 without sufficient application-level handling. The generated response could contain misleading authentication instructions, malicious links, injected markup, or instructions attempting to influence application behavior.
- **Security Impact:** User deception, phishing, malicious content execution depending on how P1 renders the response, or incorrect authentication guidance.

- **Severity:** High
- **Likelihood:** Medium
- **Mitigation Strategy:** P5 must treat all external LLM output as untrusted. Responses must undergo application-level validation and safe rendering before reaching P1. LLM output must never be interpreted as an authentication command or application instruction.
- **OWASP LLM Top 10 Mapping:** LLM02 — Insecure Output Handling.

Threat 11 — LLM Output Attempting Authentication Decisions

- **Threat ID:** T11
- **Threat Name:** AI Authentication Decision Bypass
- **STRIDE Category:** Elevation of Privilege
- **Affected Component/Data Flow:** EE1 → P4/P5 → P1; P2 remains authentication authority
- **Attack Scenario:** A user asks the chatbot to authenticate them, approve a login, reset authentication state, or declare that credentials are valid. A manipulated LLM response claims that authentication has succeeded.
- **Security Impact:** Confusion between AI assistance and actual authentication, potentially causing downstream logic or users to treat an unauthenticated user as authenticated.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation Strategy:** P4 and P5 must have no authentication authority. P1 must never interpret chatbot output as an authentication result. Only P2 can produce authentication decisions, and only P3 can create a session following successful authentication.
- **OWASP LLM Top 10 Mapping:** LLM08 — Excessive Agency.

Threat 12 — Excessive Agency Through AI Component

- **Threat ID:** T12
- **Threat Name:** Unauthorized AI Action Execution
- **STRIDE Category:** Elevation of Privilege
- **Affected Component/Data Flow:** EE1 → P4 → P5 → application environment
- **Attack Scenario:** A malicious prompt attempts to convince the chatbot or LLM integration service to perform an account modification, credential verification, authentication action, or session-related action outside its defined responsibilities.
- **Security Impact:** Privilege escalation, unauthorized account modification, authentication bypass, or session compromise.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation Strategy:** Maintain strict capability separation. P4 and P5 must not possess interfaces or authority for authentication, credential verification, account modification, or session management. AI-generated text must not be treated as executable authorization.
- **OWASP LLM Top 10 Mapping:** LLM08 — Excessive Agency.

Threat 13 — Authentication Bypass Through Chatbot Workflow

- **Threat ID:** T13

- **Threat Name:** Chatbot-Based Authentication Bypass
- **STRIDE Category:** Elevation of Privilege
- **Affected Component/Data Flow:** EE1 → P1 → P4/P5; P2/P3
- **Attack Scenario:** An attacker attempts to use the chatbot as an alternative path around P2 by asking it to confirm identity, provide access, approve an authentication attempt, or create an authenticated state.
- **Security Impact:** Unauthorized access to protected functionality.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation Strategy:** P1 must maintain a strict distinction between chatbot assistance and authentication functionality. P4/P5 cannot create authentication state. P3 must only create sessions after a successful authentication result from P2.
- **OWASP LLM Top 10 Mapping:** LLM08 — Excessive Agency.

Threat 14 — Session Token Theft

- **Threat ID:** T14
- **Threat Name:** Session Hijacking
- **STRIDE Category:** Spoofing
- **Affected Component/Data Flow:** P3 ↔ DS2
- **Attack Scenario:** An attacker obtains a valid session token or identifier through an application vulnerability or accidental exposure and attempts to use it to impersonate the associated authenticated user.
- **Security Impact:** Full session impersonation and unauthorized access under the victim's authenticated identity.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation Strategy:** P3 must securely generate, validate, rotate, expire, and invalidate session information. Session tokens must remain isolated from P4 and P5. Authentication and session state must be independently maintained rather than derived from chatbot responses.
- **OWASP LLM Top 10 Mapping:** Not directly applicable.

Threat 15 — Session Lifecycle Manipulation

- **Threat ID:** T15
- **Threat Name:** Unauthorized Session Creation or Persistence
- **STRIDE Category:** Elevation of Privilege
- **Affected Component/Data Flow:** P2 → P3 → DS2
- **Attack Scenario:** An attacker attempts to cause P3 to create or retain a session without a valid successful authentication result from P2.
- **Security Impact:** Authentication bypass and persistent unauthorized access.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation Strategy:** P3 must only create a session after receiving a valid authentication success from P2. P4/P5 must have no ability to create, modify, or validate session state. Session lifecycle decisions must remain exclusively within P3.
- **OWASP LLM Top 10 Mapping:** Not directly applicable.

Threat 16 — Session Information Leakage Through Chatbot Assistance

- **Threat ID:** T16
- **Threat Name:** Session Metadata Disclosure
- **STRIDE Category:** Information Disclosure
- **Affected Component/Data Flow:** P3/DS2 → P1/P4/P5
- **Attack Scenario:** A user asks the chatbot for information about their current session, session identifier, token, or authentication state. The application accidentally includes session metadata in the context provided to P4/P5.
- **Security Impact:** Disclosure of authentication/session information that could facilitate session compromise.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation Strategy:** P3 must not expose session tokens to AI components. P5 should have no access path to DS2. Authentication-related chatbot responses should be based only on approved documentation/context and must not disclose internal session information.
- **OWASP LLM Top 10 Mapping:** LLM06 — Sensitive Information Disclosure.

Threat 17 — Account Modification Through AI Instructions

- **Threat ID:** T17
- **Threat Name:** AI-Assisted Unauthorized Account Modification
- **STRIDE Category:** Elevation of Privilege
- **Affected Component/Data Flow:** EE1 → P4/P5 → application environment
- **Attack Scenario:** An attacker prompts the chatbot to change account information or instructs it to behave as an account-management interface. If P1, P4, or P5 treats generated content as an actionable command, an unauthorized modification could occur.
- **Security Impact:** Unauthorized modification of account information and potential account takeover.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation Strategy:** P4/P5 must have no account-modification capability. Chatbot responses must remain informational. Any actual account operation must be performed through the explicitly responsible application functionality and must enforce its own authorization.
- **OWASP LLM Top 10 Mapping:** LLM08 — Excessive Agency.

Threat 18 — Authentication Error Information Disclosure

- **Threat ID:** T18
- **Threat Name:** Authentication Enumeration
- **STRIDE Category:** Information Disclosure
- **Affected Component/Data Flow:** EE1 → P1 → P2 → P1 → EE1
- **Attack Scenario:** An attacker submits repeated authentication requests and analyzes differences in responses to determine whether a username exists or whether a particular authentication record exists in DS1.

- **Security Impact:** Account enumeration that makes credential attacks and targeted account compromise easier.
- **Severity:** Medium
- **Likelihood:** High
- **Mitigation Strategy:** P2 should return appropriately generic authentication failure information. P1 should not expose different chatbot or application responses based on whether an account exists. Authentication error behavior should not reveal sensitive information stored in DS1.
- **OWASP LLM Top 10 Mapping:** Not directly applicable.

Threat 19 — Authentication Brute-Force Abuse

- **Threat ID:** T19
- **Threat Name:** Repeated Credential Guessing
- **STRIDE Category:** Spoofing
- **Affected Component/Data Flow:** EE1 → P1 → P2 → DS1
- **Attack Scenario:** An attacker repeatedly submits login requests against an account, attempting to guess the password associated with the salted password hash stored in DS1.
- **Security Impact:** Account takeover if the password is successfully guessed.
- **Severity:** High
- **Likelihood:** High
- **Mitigation Strategy:** P2 should enforce appropriate authentication-attempt controls such as rate limiting, progressive delays, and account protection mechanisms. These controls must operate on the authentication path rather than being delegated to P4 or the LLM.
- **OWASP LLM Top 10 Mapping:** Not directly applicable.

Threat 20 — Knowledge Base Tampering

- **Threat ID:** T20
- **Threat Name:** Manipulation of Approved Authentication Context
- **STRIDE Category:** Tampering
- **Affected Component/Data Flow:** DS3 → P4/P5 → EE2
- **Attack Scenario:** Authentication guidance stored in DS3 is altered so that the LLM receives incorrect or malicious instructions as approved context.
- **Security Impact:** Incorrect authentication guidance, user deception, security-policy bypass, and potentially unsafe user actions.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation Strategy:** DS3 content used by P5 should be controlled and validated as approved documentation. P5 should distinguish repository content from authoritative system instructions. Changes to approved context should be subject to appropriate integrity controls.
- **OWASP LLM Top 10 Mapping:** LLM01 — Prompt Injection.

Threat 21 — External LLM Response Spoofing or Manipulation

- **Threat ID:** T21
- **Threat Name:** Untrusted External LLM Response

- **STRIDE Category:** Spoofing / Tampering
- **Affected Component/Data Flow:** EE2 → P5 → P4/P1
- **Attack Scenario:** The external LLM returns a response that is misleading, manipulated, or inconsistent with the application's intended authentication guidance. Because EE2 is outside the application's security control, P5 cannot inherently assume the response is trustworthy.
- **Security Impact:** Incorrect user guidance, malicious content delivery, and potential social-engineering attacks against users.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation Strategy:** P5 must treat every response from EE2 as untrusted. Application-level response handling must validate and constrain output before it reaches P1. The LLM response must never determine authentication or authorization state.
- **OWASP LLM Top 10 Mapping:** LLM02 — Insecure Output Handling.

Threat 22 — Data Leakage Across the External LLM Trust Boundary

- **Threat ID:** T22
- **Threat Name:** Unauthorized Cross-Boundary Data Transfer
- **STRIDE Category:** Information Disclosure
- **Affected Component/Data Flow:** P5 → EE2
- **Attack Scenario:** Data originating inside the trusted application environment is unintentionally transmitted to the third-party LLM provider. The attack can occur through malicious user prompts, incorrect context selection, or faulty prompt preparation.
- **Security Impact:** Confidential application data leaves the application's security boundary and becomes exposed to an external third party.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation Strategy:** P5 must enforce the stated boundary rule: only sanitized prompts and authorization-approved context may cross into EE2. Passwords, password hashes, session tokens, and secrets must be technically prevented from entering outbound LLM requests.
- **OWASP LLM Top 10 Mapping:** LLM06 — Sensitive Information Disclosure.

Threat 23 — Prompt-Based Extraction of Restricted Information

- **Threat ID:** T23
- **Threat Name:** Data Extraction via Repeated Prompting
- **STRIDE Category:** Information Disclosure
- **Affected Component/Data Flow:** EE1 → P4/P5 → EE2 → P4/P1
- **Attack Scenario:** An attacker uses multiple carefully constructed prompts to infer or extract information that should not be disclosed. The attacker may vary wording, request system details indirectly, or attempt to make the model reveal restricted context.
- **Security Impact:** Information disclosure and potential exposure of internal authentication-related information.
- **Severity:** High
- **Likelihood:** High
- **Mitigation Strategy:** P5 should minimize the context supplied to EE2 and enforce output filtering. Sensitive information must not be present in the model context merely because it is

technically inaccessible to the user. The chatbot should provide only the minimum approved authentication guidance required.

- **OWASP LLM Top 10 Mapping:** LLM06 — Sensitive Information Disclosure; LLM01 — Prompt Injection.

Threat 24 — Denial of Service Through Authentication Requests

- **Threat ID:** T24
- **Threat Name:** Authentication Resource Exhaustion
- **STRIDE Category:** Denial of Service
- **Affected Component/Data Flow:** EE1 → P1 → P2 → DS1
- **Attack Scenario:** An attacker submits a large number of registration or login requests, consuming authentication-service or database resources.
- **Security Impact:** Reduced availability of authentication functionality and potentially preventing legitimate users from logging in or registering.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation Strategy:** P2 should enforce request throttling and authentication-attempt controls. P1 should reject malformed requests before unnecessary processing. Controls must protect both P2 and its interaction with DS1.
- **OWASP LLM Top 10 Mapping:** Not directly applicable.

Threat 25 — LLM Resource Exhaustion Through Prompt Abuse

- **Threat ID:** T25
- **Threat Name:** Excessive Prompt / LLM Resource Consumption
- **STRIDE Category:** Denial of Service
- **Affected Component/Data Flow:** EE1 → P1 → P4 → P5 → EE2
- **Attack Scenario:** A malicious user submits unusually large or repeated chatbot prompts, causing P5 to repeatedly prepare requests and send them to EE2.
- **Security Impact:** Reduced availability of chatbot assistance and increased consumption of LLM processing resources.
- **Severity:** Medium
- **Likelihood:** High
- **Mitigation Strategy:** P1/P5 should enforce appropriate prompt-size and request-frequency limits. P5 should prevent unnecessarily large context from DS3 from being repeatedly transmitted to EE2.
- **OWASP LLM Top 10 Mapping:** LLM04 — Model Denial of Service.

Threat 26 — Model Abuse Through Authentication-Related Social Engineering

- **Threat ID:** T26
- **Threat Name:** AI-Assisted Authentication Deception
- **STRIDE Category:** Repudiation / Information Disclosure

- **Affected Component/Data Flow:** EE1 → P4/P5 → EE2 → P1 → EE1
- **Attack Scenario:** A malicious user attempts to manipulate the chatbot into generating convincing but incorrect authentication guidance, such as falsely claiming that a particular action proves identity or that authentication has succeeded.
- **Security Impact:** Users may be deceived into believing an authentication operation occurred when it did not, potentially leading to disclosure of credentials or other sensitive information.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation Strategy:** P4 must clearly remain an assistance layer. Authentication status must originate only from P2/P3. P1 should distinguish authoritative authentication results from AI-generated explanatory text.
- **OWASP LLM Top 10 Mapping:** LLM01 — Prompt Injection; LLM09 — Misinformation.

Threat 27 — Hallucinated Authentication Guidance

- **Threat ID:** T27
- **Threat Name:** Incorrect AI-Generated Security Guidance
- **STRIDE Category:** Tampering
- **Affected Component/Data Flow:** EE2 → P5 → P4 → P1 → EE1
- **Attack Scenario:** The external LLM generates an incorrect explanation of the authentication process despite receiving approved documentation/context.
- **Security Impact:** Users may follow incorrect authentication instructions, potentially exposing credentials or misunderstanding their authentication state.
- **Severity:** Medium
- **Likelihood:** Medium
- **Mitigation Strategy:** P5 should constrain responses using approved DS3 documentation and treat generated output as untrusted. Security-sensitive authentication claims should not be allowed to override actual P2/P3 state.
- **OWASP LLM Top 10 Mapping:** LLM09 — Misinformation.

Threat 28 — Sensitive Context Overexposure

- **Threat ID:** T28
- **Threat Name:** Excessive Context Disclosure
- **STRIDE Category:** Information Disclosure
- **Affected Component/Data Flow:** DS3 → P5 → EE2
- **Attack Scenario:** P5 sends more approved documentation/context to EE2 than is necessary for answering a particular question. Although the context does not contain passwords, hashes, session tokens, or API keys, excessive internal documentation may still reveal information useful to an attacker.
- **Security Impact:** Exposure of internal authentication procedures and system information that could support further attacks.
- **Severity:** Medium
- **Likelihood:** Medium
- **Mitigation Strategy:** P5 should apply data minimization when selecting context from DS3. Only the documentation relevant to the current question should be provided to EE2.
- **OWASP LLM Top 10 Mapping:** LLM06 — Sensitive Information Disclosure.

Threat 29 — Trust Boundary Confusion Between AI and Authentication Services

- **Threat ID:** T29
- **Threat Name:** AI Authority Confusion
- **STRIDE Category:** Elevation of Privilege
- **Affected Component/Data Flow:** P1 ↔ P2/P3/P4/P5
- **Attack Scenario:** Application logic or user interaction treats an AI-generated response as equivalent to an authoritative result from P2 or P3. For example, a chatbot response says that a user is authenticated, while P2 has not authenticated the user and P3 has not created a session.
- **Security Impact:** Authentication bypass or incorrect authorization assumptions.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation Strategy:** Maintain an explicit trust distinction: P2 is the sole authentication authority, P3 is the sole session authority, and P4/P5 are informational only. P1 must never derive security state from AI output.
- **OWASP LLM Top 10 Mapping:** LLM08 — Excessive Agency.

Threat 30 — Unauthorized Disclosure Through Chatbot Error Messages

- **Threat ID:** T30
- **Threat Name:** Internal Error Information Leakage
- **STRIDE Category:** Information Disclosure
- **Affected Component/Data Flow:** P5 → P4 → P1 → EE1
- **Attack Scenario:** An error encountered while processing an LLM request causes internal application details, prompt construction information, context-selection details, or other implementation information to be returned through the chatbot.
- **Security Impact:** Information disclosure that can help attackers understand the application's trust boundaries and attack surface.
- **Severity:** Medium
- **Likelihood:** Medium
- **Mitigation Strategy:** P5 should return controlled, user-appropriate error messages rather than exposing internal processing details. LLM provider errors and internal application errors should not automatically become chatbot-visible content.
- **OWASP LLM Top 10 Mapping:** LLM02 — Insecure Output Handling.

Threat 31 — Repudiation of Authentication Actions

- **Threat ID:** T31
- **Threat Name:** Insufficient Authentication Event Traceability
- **STRIDE Category:** Repudiation
- **Affected Component/Data Flow:** P2 → DS1; P3 → DS2
- **Attack Scenario:** Authentication and session events are performed but cannot be reliably associated with the corresponding authentication/session operation. A user or attacker could later dispute whether an authentication event or session transition occurred.

- **Security Impact:** Reduced ability to investigate authentication abuse, account compromise, or suspicious session activity.
- **Severity:** Medium
- **Likelihood:** Medium
- **Mitigation Strategy:** Authentication records in DS1 and session-related state in DS2 should preserve sufficient integrity and traceability for the operations performed by P2 and P3. P4/P5 should not become the authoritative source for authentication events.
- **OWASP LLM Top 10 Mapping:** Not directly applicable.

Threat 32 — Unauthorized Modification of Authentication Records

- **Threat ID:** T32
- **Threat Name:** Authentication Record Tampering
- **STRIDE Category:** Tampering
- **Affected Component/Data Flow:** P2 ↔ DS1
- **Attack Scenario:** Authentication records stored in DS1 are modified without authorization, potentially altering information used by P2 during authentication.
- **Security Impact:** Incorrect authentication decisions, account compromise, or denial of legitimate access.
- **Severity:** Critical
- **Likelihood:** Low
- **Mitigation Strategy:** DS1 must accept security-sensitive authentication-record operations only from P2 according to the architecture. P4 and P5 must have no access path to authentication records. Integrity protections should ensure P2 does not rely on unauthorized modifications.
- **OWASP LLM Top 10 Mapping:** Not directly applicable.

Threat 33 — Unauthorized Session Storage Modification

- **Threat ID:** T33
- **Threat Name:** Session State Tampering
- **STRIDE Category:** Tampering
- **Affected Component/Data Flow:** P3 ↔ DS2
- **Attack Scenario:** Session identifiers or session metadata in DS2 are modified so that an attacker can cause an invalid session to appear valid or extend the lifetime of an existing session.
- **Security Impact:** Session hijacking, privilege escalation, and persistent unauthorized access.
- **Severity:** Critical
- **Likelihood:** Low
- **Mitigation Strategy:** P3 must be the only component responsible for session lifecycle and validation. Session storage must preserve the integrity of session identifiers and metadata. P4/P5 must have no access to DS2.
- **OWASP LLM Top 10 Mapping:** Not directly applicable.

Threat 34 — Cross-Trust-Boundary Credential Leakage

- **Threat ID:** T34

- **Threat Name:** Credential Data Crossing the LLM Boundary
- **STRIDE Category:** Information Disclosure
- **Affected Component/Data Flow:** DS1/P2 → P5 → EE2
- **Attack Scenario:** A chatbot question asks for help with a password or login problem, and application logic accidentally incorporates credential-related information from the authentication workflow into the LLM prompt.
- **Security Impact:** Password-related information or password hashes could leave the trusted application environment and reach the third-party LLM provider.
- **Severity:** Critical
- **Likelihood:** Low
- **Mitigation Strategy:** P5 must have no access to passwords or password hashes. P2 should not pass credential material to P5. Prompt construction must enforce the architecture's explicit prohibition on credentials crossing into EE2.
- **OWASP LLM Top 10 Mapping:** LLM06 — Sensitive Information Disclosure.

Threat 35 — AI Component Used as an Authorization Oracle

- **Threat ID:** T35
- **Threat Name:** Authorization-State Inference Through Chatbot
- **STRIDE Category:** Elevation of Privilege / Information Disclosure
- **Affected Component/Data Flow:** EE1 → P4/P5 → P1
- **Attack Scenario:** An attacker repeatedly asks the chatbot questions designed to determine whether an account is authenticated, whether a session exists, or whether a user has particular account privileges.
- **Security Impact:** Disclosure of security state and potential assistance in bypassing authentication or authorization controls.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation Strategy:** P4/P5 should not receive session or authorization state unless explicitly required and permitted by the architecture. The chatbot should not act as an oracle for authentication or authorization state.
- **OWASP LLM Top 10 Mapping:** LLM06 — Sensitive Information Disclosure.

Threat 36 — Prompt Injection Combined With Output Handling

- **Threat ID:** T36
- **Threat Name:** End-to-End Prompt Injection Exploitation
- **STRIDE Category:** Tampering / Elevation of Privilege
- **Affected Component/Data Flow:** EE1 → P1 → P4 → P5 → EE2 → P5 → P1
- **Attack Scenario:** An attacker submits a malicious prompt designed to manipulate the LLM into generating content that P5 or P1 subsequently handles as trusted. The attack combines prompt injection with insufficient validation of the generated response.
- **Security Impact:** Security-control bypass, malicious content delivery, misinformation, or potential application compromise depending on how output is processed.
- **Severity:** Critical
- **Likelihood:** High

- **Mitigation Strategy:** Defend both sides of the LLM interaction: sanitize and structure user/context input before sending it to EE2, and validate every response after it returns. Never allow generated content to directly control P2, P3, account operations, or security state.
- **OWASP LLM Top 10 Mapping:** LLM01 — Prompt Injection; LLM02 — Insecure Output Handling; LLM08 — Excessive Agency.

Threat 37 — Sensitive Information Leakage Through Conversation Context

- **Threat ID:** T37
- **Threat Name:** Conversational Context Leakage
- **STRIDE Category:** Information Disclosure
- **Affected Component/Data Flow:** EE1 → P1 → P4/P5 → EE2
- **Attack Scenario:** A user deliberately includes sensitive information in chatbot prompts, such as credentials or account details. P5 forwards the entire prompt to EE2 because it assumes that all user-provided chatbot content is safe to transmit.
- **Security Impact:** User-provided sensitive information crosses the application's external trust boundary.
- **Severity:** High
- **Likelihood:** High
- **Mitigation Strategy:** P5 should sanitize user-provided chatbot prompts before sending them to EE2 and minimize the data transmitted. The system should not assume that because information originated from the user, it is safe to send to the external LLM provider.
- **OWASP LLM Top 10 Mapping:** LLM06 — Sensitive Information Disclosure.

Threat 38 — Unbounded LLM Reliance for Security-Critical Information

- **Threat ID:** T38
- **Threat Name:** Security Decision Delegation to the LLM
- **STRIDE Category:** Elevation of Privilege
- **Affected Component/Data Flow:** P4/P5 ↔ P1/P2/P3
- **Attack Scenario:** Application behavior gradually treats the LLM as authoritative for determining whether a user has successfully authenticated, whether credentials are valid, or whether a session should exist.
- **Security Impact:** Fundamental authentication bypass and loss of separation between the AI assistance layer and security-critical components.
- **Severity:** Critical
- **Likelihood:** Low
- **Mitigation Strategy:** Maintain the explicit architectural invariant that **P2 alone authenticates and P3 alone manages sessions**. P4/P5 must remain incapable of making or enforcing those decisions, regardless of what the LLM generates.
- **OWASP LLM Top 10 Mapping:** LLM08 — Excessive Agency.

Threat 39 — Model Denial of Service Through Repeated Adversarial Queries

- **Threat ID:** T39
- **Threat Name:** Adversarial LLM Query Flooding
- **STRIDE Category:** Denial of Service
- **Affected Component/Data Flow:** EE1 → P1 → P4 → P5 → EE2
- **Attack Scenario:** An attacker repeatedly submits computationally expensive or unusually long chatbot requests, forcing P5 to repeatedly prepare prompts and interact with EE2.
- **Security Impact:** Reduced availability of the chatbot and potentially increased processing/resource consumption within P5.
- **Severity:** Medium
- **Likelihood:** High
- **Mitigation Strategy:** Limit chatbot request frequency and prompt size at P1/P5. Reject excessively large or malformed prompts before invoking EE2. Ensure chatbot resource consumption cannot interfere with P2/P3's authentication and session responsibilities.
- **OWASP LLM Top 10 Mapping:** LLM04 — Model Denial of Service.

Threat 40 — Loss of Security Boundary Due to Future Capability Creep

- **Threat ID:** T40
- **Threat Name:** AI Capability Creep
- **STRIDE Category:** Elevation of Privilege
- **Affected Component/Data Flow:** P4/P5 ↔ P2/P3/DS1/DS2
- **Attack Scenario:** A future change gives P4 or P5 access to account operations, credential information, authentication state, or session functionality because the chatbot is expanded beyond its current assistance-only purpose.
- **Security Impact:** The AI component could become an attack path to authentication bypass, credential disclosure, account takeover, or session compromise.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation Strategy:** Preserve the architectural restrictions as explicit security requirements: P4/P5 must not authenticate users, verify credentials, access password hashes, access session tokens, or modify accounts. Any future capability should be treated as a new trust-boundary decision and separately threat-modelled.
- **OWASP LLM Top 10 Mapping:** LLM08 — Excessive Agency.